Web Security Assessment Report

Target: https://sca-system.netlify.app
Assessment Date: 10 October 2026
Assessment Type: Preliminary Web Security Assessment
Platform: Netlify

1. Objective

To assess publicly accessible security configurations and frontend resources of the Shezad Children Academy School Management System through limited, authorized security checks.

2. Tests Performed

- HTTPS connectivity and HTTP-to-HTTPS redirection
- HTTP security header inspection
- `robots.txt` and `manifest.json` checks
- `security.txt` path inspection
- Public JavaScript bundle review
- Basic searches for potentially exposed secrets and API paths
- Limited manual login/logout and role-visibility checks

3. Observations

Observation 1: HTTP Security Headers

HSTS was present in the inspected response. Other checked headers, including Content-Security-Policy, X-Frame-Options, X-Content-Type-Options, Referrer-Policy, and Permissions-Policy, were not observed in that response.

Recommendation: Review the applicable security headers and configure them according to the application's requirements.

Observation 2: security.txt

The `/.well-known/security.txt` path returned HTML rather than a dedicated security.txt document.

Recommendation: Consider publishing a valid security.txt file to provide security contact and vulnerability-reporting information.

Observation 3: Frontend JavaScript

Generic password-related code and localStorage usage were observed. The performed searches did not identify a confirmed exposed secret or password.

Recommendation: Review browser storage and ensure sensitive information, such as authentication secrets, is not stored insecurely.

Observation 4: Authentication and Role Visibility

Limited manual login/logout and role-visibility checks were performed. These checks did not establish a confirmed access-control vulnerability. Server-side authorization was not independently verified.

Recommendation: Verify authorization on the server for every protected operation and test role permissions using dedicated test accounts.

4. Recommendations

- Review and configure appropriate HTTP security headers.
- Publish a valid security.txt file if appropriate.
- Review client-side storage for sensitive information.
- Validate server-side authentication and authorization.
- Continue testing backend APIs and role-based access controls within the authorized scope.

5. Limitations

This was a preliminary, non-invasive assessment focused mainly on publicly accessible resources, with limited manual authentication and role-visibility checks. A comprehensive backend security review, source-code audit, and independent verification of server-side authorization were not performed.

6. Conclusion

The assessment identified configuration items that warrant review. No exploitable vulnerability was confirmed by the checks performed. Further authorized testing is recommended before making broader conclusions about the application's security.

7. Evidence

- `evidence/headers-check.txt` — HTTP response headers
- `report.md` — Editable assessment report
- `report.pdf` — PDF version of the report

Disclaimer: Findings reflect only the checks performed against the specified target on the assessment date. They do not guarantee that the application is free of vulnerabilities.